

RAPPORT GRC

Gouvernance - Risques - Conformité

Projet PixelStore - Infrastructure AWS sécurisée

Auteurs : Jimmy Barbier - Dorian Poncelet - Matthieu Broquard

Jedha Bootcamp - Cybersécurité Fullstack - Juin 2026

Référentiels : ISO 27001:2022 - NIST CSF 2.0 - FAIR - RGPD - Classification : CONFIDENTIEL

Mise à jour - remédiation appliquée. Depuis l'analyse initiale, l'équipe a remédié l'intégralité des constats techniques du pentest (F1-F8 + F9 Open Redirect) dans le code déployé. La quantification FAIR ci-dessous

est **recalculée** en conséquence : l'exposition résiduelle passe de ~192 000 € à ~17 000 €/an. Les écarts restants sont **organisationnels** (gouvernance, réponse/reprise, RGPD).

1. Présentation du projet

PixelStore est une application e-commerce de vente de smartphones (Flask 3.1 / Python) déployée sur AWS via Terraform (IaC). L'analyse GRC porte sur l'intégralité du périmètre technique et organisationnel - application, infrastructure, pratiques de développement et gestion de projet - réalisée en équipe par Jimmy Barbier, Dorian Poncelet et Matthieu Broquard.

Composant	Détail	Statut sécurité
Application	Flask 3.1 - 9 smartphones (799-1 899 €)	HTTPS via Cloudflare + durcissement applicatif
Compute	EC2 Auto Scaling - t2.micro min1/max2	SSM Session Manager (sans clé SSH), exécution non-root
Load Balancer	ALB - Multi-AZ eu-west-3	WAF (OWASP + SQLi + RateLimit), restreint aux IP Cloudflare
Base de données	RDS MySQL Multi-AZ - db.t3.micro	Chiffré au repos - subnet privé
Stockage	S3 - assets statiques	Chiffré SSE-S3, accès public bloqué
Secrets	AWS Secrets Manager	Credentials RDS + SECRET_KEY forte (64 car.)
Observabilité	CloudWatch + GuardDuty + CloudTrail	Actif - alertes SNS
IaC	Terraform - 17 modules - 77 ressources	1 terraform apply (~15 min)
RPO / RTO	RPO ~15 min (snapshot 12 h + binlogs/PITR)	RTO ~15 min (terraform apply)

2. Méthodologie d'analyse

Trois phases indépendantes, trois référentiels complémentaires, chacun produisant un résultat quantifié.

Phase	Référentiel	Échelle	Résultat
Conformité	ISO 27001:2022	CMMI 0 -> 5 (cible >= 3)	Maturité par contrôle
Maturité	NIST CSF 2.0	Tier 1 -> 4 (cible Tier 3)	Score par fonction
Financier	FAIR (Monte Carlo)	ALE en € (P50/P90/P95)	Exposition annuelle

Sources : code Flask, infrastructure Terraform (17 modules), rapport de pentest interne (F1-F9), configuration AWS (WAF, SG, NACLs, IAM, CloudWatch), documentation projet.

3. Gap Analysis ISO 27001:2022

Indicateur	Valeur
Contrôles évalués	93 / 93 (100%)
Conformes (maturité >= 3)	26 / 93 - 28%
Score moyen	1,72 / 5
Verdict	Programme de mise en conformité 12-18 mois (axe organisationnel)

Thème	Contrôles	Score	Niveau
A.7 - Physiques	14	3,29 / 5	Satisfaisant (délégué à AWS)
A.8 - Technologiques	34	1,97 / 5	En amélioration (cf. remédiation pentest)
A.5 - Organisationnels	37	1,22 / 5	Critique
A.6 - Personnels	8	0,25 / 5	Critique

Les écarts dominants sont **organisationnels et humains** (A.5/A.6) : contact autorités, réponse/évaluation des incidents, NDA, politique RH - non couverts en contexte académique. Côté technologique (A.8), les contrôles liés au pentest ont été remédiés :

Contrôle	Intitulé	Lien pentest	Statut
A.8.24	Cryptographie	F1 - HTTPS	Corrigé (TLS via Cloudflare)
A.8.11	Masquage de données	F5 - Énumération	Corrigé (message générique)
A.8.5	Authentification sécurisée	F7 - Mots de passe	Corrigé (politique serveur)
A.8.31	Séparation dev/test/prod	F8 - SECRET_KEY	Partiel (clé forte OK ; séparation env. à faire)

4. Scoring maturité NIST CSF 2.0

Indicateur	Valeur
Sous-catégories évaluées	77 / 77
Score moyen global	0,69 / 4 - Tier 1 (Partial)
Objectif cible	Tier 3 (Repeatable)

Fonction	Score	Observation
PR - Protect	1,18 / 4	Bonne base (IAM, chiffrement, réseau) - renforcée par la remédiation
ID - Identify	0,83 / 4	Cartographie des flux à compléter
DE - Detect	0,73 / 4	Corrélation d'événements absente
GV - Govern	0,62 / 4	Aucune politique formalisée
RC - Recover	0,25 / 4	CRITIQUE - plan de reprise non documenté
RS - Respond	0,23 / 4	CRITIQUE - aucune procédure de réponse

Les fonctions **RS (Respond)** et **RC (Recover)** restent les priorités : créer un plan de réponse à incident, tester la restauration RDS, documenter le terraform apply comme PRA.

5. Quantification FAIR - exposition financière (recalculée)

Trois scénarios modélisés via Monte Carlo (10 000 itérations) : ALE = LEF x LM. Après remédiation de F1 (TLS) et F8 (SECRET_KEY), ces deux scénarios sont neutralisés.

Scénario	Source	ALE moyen /an	P90 /an	Statut
F1 - HTTP en clair (interception)	Pentest F1	0 € (av. 144 800 €)	0 € (av. 275 000 €)	Corrigé (Cloudflare)
F8 - SECRET_KEY faible (forge session)	Pentest F8	0 € (av. 30 200 €)	0 € (av. 57 200 €)	Corrigé (clé forte)
RGPD - Fuite BDD (notification CNIL)	Analyse infra	17 000 €	33 700 €	Résiduel (mitigé)
TOTAL exposition résiduelle		~17 000 €	~34 000 €	< cible 30 k€

Réduction obtenue : -175 000 €/an d'exposition (de ~192 000 € à ~17 000 €). L'exposition résiduelle (scénario RGPD) est déjà mitigée par l'architecture (RDS en subnet privé, Security Groups restrictifs, TLS) et passe sous le seuil cible de 30 000 €/an. Lecture : P90 = perte annuelle non dépassée dans 90 % des simulations, référence pour le budget de défense.

Scénario RGPD - facteur FAIR	Min	Mode	Max
TEF (fréquence /an)	0,05	0,20	1,00
Vuln (probabilité)	0,10	0,25	0,50
PLM (perte directe)	10 k€	50 k€	200 k€
SLM (perte secondaire)	20 k€	80 k€	500 k€

6. Plan de traitement des risques

P1 - Réalisé (durcissement code, < 1 semaine)

Action	Lien	ALE réduit	Statut
TLS/HTTPS (Cloudflare)	A.8.24 / FAIR F1	-144 800 €/an	Fait
SECRET_KEY forte (Secrets Manager)	A.8.31 / FAIR F8	-30 200 €/an	Fait
En-têtes de sécurité HTTP	A.8.26 / F3	Réduction F3	Fait
Cookies de session durcis + politique MDP	A.8.5/A.8.26 / F4/F7	Réduction F4/F7	Fait
Correction Open Redirect (F9)	Hors pentest	-	Fait

P2 - Court terme (< 1 mois) - Gouvernance

- Politique de réponse aux incidents (ISO A.5.26 / NIST RS).
- Registre des traitements RGPD Art.30.
- Engagements de confidentialité / NDA (ISO A.6.6).

- Canal de signalement sécurité (ISO A.6.8).
- Test de restauration RDS snapshot (NIST RC.RP-03).

P3 - Moyen terme (1-6 mois) - Maturité

- Séparation des environnements dev / test / prod (ISO A.8.31).
- Inventaire et classification des actifs (ISO A.5.9/A.5.12).
- Clause sécurité fournisseur AWS (ISO A.5.19/A.5.20).
- Plan de continuité documenté - PCA/PRI (NIST RC.RP-01).

7. Synthèse et recommandations

Référentiel	Score actuel	Cible	Verdict
ISO 27001:2022	1,72 / 5 (28%)	4,0 / 5	Programme 12-18 mois (organisationnel)
NIST CSF 2.0	Tier 1 - 0,69 / 4	Tier 3	Actions immédiates RS/RC
FAIR - ALE résiduel	~17 000 €/an (av. ~192 000 €)	< 30 000 €/an	Cible atteinte (-175 k€/an)
RGPD	Non conforme Art.30	Registre + DPO	Registre à créer

Points forts

Architecture Defense in Depth (VPC Multi-AZ, SG en cascade, NACLs) - IAM moindre privilège, SSM sans SSH - Secrets Manager - chiffrement au repos - WAF - observabilité (CloudWatch/GuardDuty/CloudTrail) - IaC reproductible - **vulnérabilités applicatives toutes remédiées** (TLS, en-têtes, cookies, SECRET_KEY forte, politique MDP, anti-énumération, open redirect).

Points de risque persistants (organisationnels)

- Gouvernance personnelle (A.6) : aucun NDA, aucune procédure RH.
- Plan de réponse aux incidents (NIST RS 0,23) inexistant.
- Plan de reprise formalisé (NIST RC 0,25) non documenté.
- Registre RGPD Article 30 inexistant.
- Séparation dev/test/prod à mettre en place.

Conclusion - L'infrastructure présente une base technique solide, désormais renforcée par la remédiation complète des constats du pentest : l'exposition financière chute de ~192 k€ à ~17 k€/an. Les efforts restants se concentrent sur la gouvernance organisationnelle (A.5/A.6) et les procédures de réponse et de reprise (RS/RC). Rapport réalisé en équipe - Jimmy Barbier - Dorian Poncelet - Matthieu Broquard - Jedha Bootcamp Cybersécurité Fullstack.